
Sesiones, token y acceso de los invitados

Con el informe de verificación de lo entregado hasta ahora

Documento **SLCP-ADR-0005** – Versión **1.0**

Estado: **PROPOSED**

7 de agosto de 2026

Este registro contiene tres cosas. Primero, el resultado de verificar lo entregado hasta ahora, que localizó un defecto en el esquema y su corrección, ya comprobada. Segundo, el análisis de dónde debe guardarse el token de sesión, que obliga a matizar la premisa de que la protección de datos limita el uso de cookies: limita unas y no otras, y la distinción cambia la decisión. Y tercero, el análisis del ingreso de las personas invitadas por un facilitador, que es el flujo con más aristas de cuantos lleva el producto.

Índice

1	Informe de verificación	2
1.1	Qué se pudo verificar y qué no	2
1.2	El defecto encontrado	2
1.3	Qué enseña este hallazgo	3
2	Dónde se guarda el token de sesión	3
2.1	La premisa que conviene matizar	3
2.2	Las tres opciones y lo que cuesta cada una	3
2.3	Decisión propuesta	4
3	Ingreso de las personas invitadas	4
3.1	El problema	4
3.2	Los cuatro riesgos y cómo se atajan	5
3.3	Qué ocurre si el correo ya tiene cuenta	6
3.4	Diferencia con el autorregistro, y por qué existe	6
4	Qué verá cada rol	6
5	Orden de construcción propuesto	7

1 Informe de verificación

1.1 Qué se pudo verificar y qué no

Tabla 1: Alcance de la verificación realizada

Artefacto	Resultado	Cómo se comprobó
Módulo de nomenclatura	Verificado	76 vectores de conformidad en verde
Hook de mensajes de commit	Verificado	13 comprobaciones en verde, y el rechazo confirmado en uso real
Interfaz: tipos	Verificado	Comprobación de tipos en modo estricto, sin errores
Interfaz: plantillas	Verificado	Compilador de Angular con <i>strictTemplates</i> , sin errores
Esquema de base de datos	Defecto corregido	Ejecutado contra PostgreSQL 16 real; ver Sección 1.2
Servicio Java	No verificado	Sin acceso al repositorio de artefactos de Maven

La comprobación de la interfaz se validó a su vez con un control negativo: se introdujo a propósito un error en una plantilla, se confirmó que el compilador lo detectaba, y se restauró el archivo. Sin ese control, un resultado en verde solo demostraría que la herramienta se ejecutó, no que comprueba algo.

1.2 El defecto encontrado

La migración inicial imponía unicidad sobre el nombre de usuario y sobre el correo por separado. Aparentaba cumplir FUN-03, que exige que la resolución entre ambos identificadores no sea ambigua, y no lo cumplía: se aceptaba sin obstáculo una cuenta cuyo nombre de usuario fuese el correo de otra persona.

Nombre de usuario	Correo	Resultado
gguerrero	gguerrero@uteq.edu.ec	Aceptada
gguerrero@uteq.edu.ec	distinto@uteq.edu.ec	Aceptada también

Con ambas cuentas en el sistema, quien escribiese `gguerrero@uteq.edu.ec` en el formulario de acceso estaría designando a dos personas a la vez. Agravante: el comentario del propio archivo afirmaba que un índice lo impedía.

Corrección. Los dos identificadores pasan a compartir un único espacio de nombres, en una tabla cuya clave primaria impone la unicidad sobre el conjunto. Comprobado contra PostgreSQL real: ambos casos de ambigüedad quedan rechazados y, al deshacerse la transacción, no queda cuenta huérfana alguna.

1.3 Qué enseña este hallazgo

Merece anotarse porque es exactamente el modo de fallo contra el que se diseñó el proyecto. El defecto no estaba en la lógica sino en la distancia entre lo que el comentario afirmaba y lo que el código hacía. Ninguna revisión de lectura lo habría detectado, porque leer el comentario tranquiliza. Lo detectó ejecutar la comprobación contra un motor real.

2 Dónde se guarda el token de sesión

2.1 La premisa que conviene matizar

Se indicó que la privacidad de datos limita el uso de cookies. Es cierto a medias, y la mitad que falta cambia la decisión técnica.

Lo que la normativa restringe son las cookies que tratan datos personales con fines de analítica, publicidad o seguimiento, para las que exige consentimiento previo, libre, específico e informado. Las estrictamente necesarias para que el servicio funcione, entre ellas las de gestión de sesión, no recogen datos personales en su configuración habitual y pueden establecerse sin consentimiento [1].

Dicho de otro modo: la restricción no impide autenticar mediante cookie. Impide rastrear.

2.2 Las tres opciones y lo que cuesta cada una

Tabla 2: Almacenamiento del token

Opción	Riesgo principal	Coste
Cookie con marca <i>HttpOnly</i>	Falsificación de petición entre sitios, que se ataja con <i>SameSite</i> y con token de formulario	Ninguno para la persona usuaria. No exige consentimiento por ser estrictamente necesaria
Almacenamiento local del navegador	Cualquier script inyectado puede leerlo. Es legible por JavaScript por definición	Ninguno aparente, y ahí está el problema: parece la opción sencilla
Solo en memoria	Ninguno de los dos anteriores	La sesión se pierde al recargar la página. Sin cookie no hay renovación silenciosa posible

La opción intermedia es la que se elige por costumbre y la peor de las tres en seguridad. Un token en el almacenamiento local es legible por cualquier código que llegue a ejecutarse en la página, y basta una dependencia comprometida del ecosistema de paquetes para que ese código exista. La marca *HttpOnly* existe precisamente para que el navegador guarde algo que el propio JavaScript de la página no puede leer.

2.3 Decisión propuesta

El token de sesión viaja en una cookie *HttpOnly*, *Secure* y *SameSite=Strict*, de duración corta, acompañada de un token de renovación igualmente en cookie. La plataforma no establece ninguna otra cookie: sin analítica, sin publicidad, sin seguimiento. Al no haber cookies no necesarias, no hace falta banner de consentimiento, y la política de privacidad puede declarar con verdad que solo se emplean las imprescindibles.

SEC-01 Token en cookie no legible por script. [N1]

El token de sesión debe entregarse en una cookie con las marcas *HttpOnly*, *Secure* y *SameSite=Strict*. No debe escribirse en el almacenamiento local ni de sesión del navegador, ni quedar accesible al código de la página.

Verificación: Una inspección del almacenamiento del navegador no revela el token, y su lectura desde la consola devuelve vacío.

SEC-02 Ninguna cookie no necesaria. [N1]

La plataforma no debe establecer cookies de analítica, publicidad ni seguimiento. Toda cookie que establezca debe ser estrictamente necesaria para prestar el servicio solicitado.

Verificación: El inventario de cookies contiene únicamente las de sesión y renovación, y la política de privacidad las enumera.

SEC-03 Token de vida corta con renovación. [N1]

El token de acceso debe caducar en minutos y renovarse mediante un token de renovación de vida mas larga, revocable. El cierre de sesión debe revocar ambos en el servidor y no limitarse a borrarlos en el navegador.

Verificación: Un token revocado deja de admitirse aunque no haya caducado.

SEC-04 Contenido mínimo del token. [N1]

El token no debe contener datos personales más allá del identificador interno de la cuenta. Los roles se resuelven por proyecto en el momento de autorizar, conforme a ROL-01, y no se incrustan en el token.

Verificación: El contenido descodificado del token no revela nombre, correo ni pertenencia a proyectos.

SEC-04 merece explicación porque contradice la práctica habitual de meter los roles dentro del token. Aquí no sirve: ROL-01 establece que el rol se resuelve respecto del proyecto sobre el que se actúa, no respecto de la cuenta, de modo que un token con roles incrustados o bien no dice nada útil o bien queda obsoleto en cuanto el facilitador cambia una asignación.

3 Ingreso de las personas invitadas

3.1 El problema

El facilitador invita indicando un correo y un rol. Esa persona todavía no existe en el sistema: no tiene cuenta, no tiene contraseña, y sin embargo su membresía ya consta, porque FUN-17

exige que el proyecto pueda planificarse antes de que se registre.

Hay por tanto una cuenta a medio existir, y el modo en que se completa es donde se concentran los riesgos.

3.2 Los cuatro riesgos y cómo se atajan

Suplantación por enlace filtrado. Quien tenga el enlace puede completar el registro. El correo es un canal que se reenvía, se archiva y a veces se comparte.

INV-01 Enlace ligado, de un solo uso y caducable. [N1]

El enlace debe portar un identificador aleatorio de suficiente entropía, ligado al correo y al proyecto concretos, valido una sola vez y con caducidad. Su consumo debe invalidarlo de inmediato, y el sistema debe almacenar unicamente su huella y no el valor.

Verificación: Un enlace usado, caducado o presentado para otro correo se rechaza, y una inspección del almacen no permite reconstruir ningun enlace vigente.

Elevación de privilegio. Si el formulario de compleción aceptara el rol, la persona invitada elegiría el suyo.

INV-02 El rol viaja con la invitación, no con el formulario. [N1]

El rol lo fija el facilitador al invitar y no debe poder alterarse al completar el registro. El formulario de compleción no debe contener campo de rol alguno, ni siquiera oculto.

Verificación: Una petición de compleción que incluya rol se rechaza, y el rol resultante coincide siempre con el registrado en la invitación.

Revelación de información a una dirección no verificada. Hasta que alguien complete el registro, no consta que el correo pertenezca a quien se pretende.

INV-03 El correo se verifica al completar, no antes. [N1]

Consumir el enlace constituye la verificación del correo. Mientras la invitación siga pendiente, el sistema no debe revelar a esa dirección mas que el nombre del proyecto y quien invita, conforme a FUN-20.

Verificación: El mensaje enviado a una dirección no verificada no contiene requisitos, artefactos ni identidades del equipo.

Cuenta a medias que nunca se completa. La membresía consta, cuenta para la planificación y no corresponde a nadie.

INV-04 Visibilidad de lo pendiente. [N1]

Las membresías en estado de invitación deben distinguirse de las activas en toda la interfaz y en los informes, y su antigüedad debe reportarse al facilitador.

Verificación: El equipo del proyecto muestra quien ha aceptado y quien no, sin que haya que deducirlo.

3.3 Qué ocurre si el correo ya tiene cuenta

INV-05 Sin cuentas duplicadas. [N1]

Si el correo invitado corresponde a una cuenta existente, no debe crearse cuenta nueva ni pedirse contraseña: debe añadirse la membresía y notificarse a la persona para que la acepte o la rechace.

Verificación: Un mismo correo no produce nunca dos cuentas, y la incorporación a un proyecto nuevo no exige repetir el registro.

3.4 Diferencia con el autorregistro, y por qué existe

	Facilitador	Persona invitada
Cómo llega	Se registra por su cuenta	La invita un facilitador
Quién responde de ella	El administrador, que aprueba	El facilitador que la invitó
Aprobación administrativa	Obligatoria	No procede
Alcance de la cuenta	Puede crear proyectos	Limitado al proyecto que la originó

La asimetría no es arbitraria: el administrador aprueba a quien podrá crear proyectos, porque esa capacidad compromete recursos de la institución. Quien solo participa en un proyecto ajeno no compromete nada que su facilitador no haya comprometido ya, y exigir una segunda aprobación añadiría una espera sin beneficio.

4 Qué verá cada rol

La interfaz no oculta lo que no corresponde: lo muestra inaccesible cuando su existencia es información útil, y lo omite cuando su mera presencia revelaría algo. La regla es la misma que gobierna los informes en RPT-04: la interfaz no puede revelar lo que la autorización niega.

Tabla 3: Ambito de cada rol en la interfaz

Rol	Su pantalla de inicio	Lo que puede hacer
Visitante	Portada pública	Conocer la plataforma, solicitar registro, iniciar sesión
Administrador	Solicitudes pendientes de aprobar	Aprobar y rechazar registros, dar de baja, ver metadatos agregados. Nunca el contenido de un proyecto
Facilitador	Sus proyectos, con avance declarado y aceptado	Crear proyectos, planificar, invitar, aprobar la línea base
Miembro del equipo	Su trabajo pendiente en los proyectos donde participa	Requisitos, generación, modificación, sus propios datos
Propietario	Lo que espera su aprobación	Consultar todo el proyecto, aprobar o reprobar. Ninguna escritura

SEC-05 La interfaz no es el control de acceso. [N1]

Toda restricción visible en la interfaz debe estar impuesta además en el servicio. Ocultar una opción no debe ser nunca el único impedimento para ejecutarla.

Verificación: Una petición construida a mano contra un recurso no autorizado se rechaza con el mismo resultado que si la interfaz nunca hubiera mostrado la opción.

5 Orden de construcción propuesto

1. Autenticación: verificador de contraseña, emisión y renovación de token, cierre de sesión con revocación.
2. Aprobación de solicitudes por el administrador, con su pantalla.
3. Proyectos, equipo e invitaciones, con la compleción de registro de la Sección 3.
4. Armazón de la interfaz por rol, con la pantalla de inicio de cada uno.

El armazón por rol va el último a propósito: sin autenticación no hay rol que distinguir, y construir las pantallas antes obligaría a simular la sesión, con lo que ninguna quedaría verificada de verdad.

Referencias

- [1] Asamblea Nacional del Ecuador. Ley orgánica de protección de datos personales. Registro Oficial, Quinto Suplemento N.º 459, 26 de mayo de 2021, 2021. <https://www.telecomunicaciones.gob.ec/wp-content/uploads/2021/06/Ley-Organica-de-Datos-Personales.pdf>.